Supplier AI Due-Diligence Questionnaire
The Council · AI Governance Playbook (Level 5 document, §5.5)

The Council includes AI-specific requirements in the procurement and contracting of any system with an AI component (Playbook §5.5). Suppliers should complete sections 1–9 in full. The Council completes the evaluation in section 10. Responses may form part of the contract.

Existing contracts, licence features and free tools (Proposed — for Council confirmation). Gate 4 (Procurement, AIG-DEC-01) applies wherever a procurement, new contract, licence change or contract variation is needed. For an AI feature enabled under an existing contract or licence, or a free public tool, Gate 4 is recorded as "N/A — existing contract / free tool" with the rationale, but the supplier checks that still apply are completed: the data processing terms, section 5 (Data Protection and Security) and section 8 (Business Continuity, including exit). Where the supplier will not complete this questionnaire (for example a free public tool), the Service Owner answers those sections from the published terms and records any gaps.

1. Supplier and Product

Supplier / company name	
Contact name and email	
Product / system name & version	
Brief description of the product	
Council procurement reference	If known
AIR-ID	AIR-XXXX
UC-ID(s) / supplier use	List each Council use to which these answers apply; use risk ___; priority ___.

Supplier evidence applicability — map each answer/evidence item to the UC-ID(s) it supports. Shared supplier evidence may be referenced, but service context, integration, data, use-specific risk and residual controls remain per UC-ID. Supplier assurance is not Council approval.

2. AI Capability and Models

2.1 Which AI techniques or models does the product use (e.g. generative, predictive, computer vision, NLP)? Name any third-party or foundation models relied upon.

2.2 Is any part of the AI provided or hosted by a sub-processor or third party? List them and their role.

3. Transparency

3.1 What information can you provide about training data, including its sources and representativeness?

3.2 What are the known limitations and failure modes of the AI?

3.3 What performance characteristics can you share (accuracy, error rates, benchmarks and the conditions under which they were measured)?

4. Responsible AI Alignment

4.1 What bias and fairness testing has been carried out, and can you share results across relevant groups?

4.2 How are the AI's outputs explained to users and to affected individuals?

4.3 How does the product support meaningful human oversight, review and override?

4.4 What information can you provide on the energy use and carbon footprint of the AI (training and operation), the locations of the data centres used, and your sustainability commitments? (Proposed — for Council confirmation)

5. Data Protection and Security

5.1 How does the product comply with UK GDPR? Will it process personal or special category data, and on what basis?

5.2 Where is data hosted and processed, and is any data used to train or improve your models?

5.3 What security certifications and controls are in place (e.g. ISO 27001, Cyber Essentials, penetration testing)?

5.4 Is the product secure by default: are the most secure settings the default, and are administrative and high-risk features switched off until the Council chooses to turn them on? (NCSC guideline 3.5; Proposed — for Council confirmation)

5.5 How are the model and its weights protected against extraction or tampering, and how do you check the integrity of model updates before release? (NCSC guideline 3.2; Proposed — for Council confirmation)

5.6 Do you have a published vulnerability disclosure process? How, and how quickly, will you tell the Council about vulnerabilities affecting the product and about the fixes? (NCSC guideline 4.4; Proposed — for Council confirmation)

5A. Contract, Transfer and Security Assurance

Answer each question and attach the proposed contractual schedule, assurance evidence or a tracked remediation action.

Supplier question	*Response, evidence and proposed contractual provision*
5A.1 UK GDPR Article 28 processor terms	Set out controller/processor roles and terms covering documented instructions, confidentiality, security, data-subject rights, breach and DPIA assistance, deletion/return and audit evidence.
5A.2 Sub-processors	List every sub-processor, role and processing location; explain prior authorisation, change notification, Council objection rights and equivalent contractual flow-down.
5A.3 International transfers	Identify each destination and safeguard (UK adequacy regulations, IDTA or UK Addendum as applicable), plus transfer risk assessment and supplementary measures.
5A.4 Incident notification and cooperation	State contractual notification deadlines for personal-data, cyber and AI incidents; 24/7 contacts; evidence preservation; investigation cooperation; and support for regulator or data-subject notification.
5A.5 Vulnerability management and patching	Provide the disclosure channel, severity method, current independent test evidence, remediation deadlines, critical-patch service level and process for accepted residual vulnerabilities.
5A.6 Supplier personnel assurance and training	Describe screening where proportionate, role-based security/data-protection/Responsible-AI training, privileged-access controls and completion evidence.

6. Audit Rights

6.1 What rights and mechanisms will the Council have to assess the AI's performance, bias and compliance during the contract?

7. Change Notification

7.1 How and when will you notify the Council of material changes to AI models, training data or functionality?

8. Business Continuity

8.1 What business continuity, support and exit arrangements apply, appropriate to the criticality of the system, including return or deletion of Council data on termination?

9. Declarations

Completed by	
Position	
Signature	
Date	

10. Council Evaluation (internal)

Completed by the Service Owner with the AI Governance Lead. Rate each area and note any contractual provisions or conditions required before award.

Area	Rating	Notes / contractual provision required
AI capability and models	Strong / Adequate / Needs work / Not addressed	
Transparency	Strong / Adequate / Needs work / Not addressed	
Responsible AI alignment	Strong / Adequate / Needs work / Not addressed	
Data protection and security	Strong / Adequate / Needs work / Not addressed	
Audit rights	Strong / Adequate	

Area	Rating	Notes / contractual provision required
	/ Needs work / Not addressed	
Change notification	Strong / Adequate / Needs work / Not addressed	
Business continuity	Strong / Adequate / Needs work / Not addressed	
Processor and sub-processor terms	Strong / Adequate / Needs work / Not addressed	
International data transfers	Strong / Adequate / Needs work / Not addressed	
Incident and vulnerability management	Strong / Adequate / Needs work / Not addressed	
Supplier personnel assurance	Strong / Adequate / Needs work / Not addressed	

Overall recommendation	Proceed / Proceed with conditions / Do not proceed
Pre-procurement AI assessment completed?	Yes / No (§5.5.1)
Evaluated by	
Date	

Document control
Administrative control record. This artefact remains a working draft until formally approved.

Field	Controlled value
Document ID	AIG-ASS-08
Version	1.9 draft
Status	Draft for Council review
Document owner	Commercial and Procurement Lead
Approving body	Pending — competent Council authority under confirmed Constitution / Scheme of Delegation; AI Assurance Board provides assurance and is not presumed to hold approval authority.
Approval date	Not yet approved
Effective date	Not yet effective
Next review date	To be set on approval: 12 months after the effective date, or sooner following material change

Field	Controlled value
Classification	OFFICIAL

Change history

Version	Date	Change summary	Owner
1.0 draft	6 August 2026	Document-control baseline established following full-suite quality assurance; no substantive content change.	Commercial and Procurement Lead
1.1 draft	6 August 2026	QA revision: added processor, sub-processor, transfer, incident, vulnerability and supplier-personnel controls.	Commercial and Procurement Lead
1.2 draft	19 September 2026	QA revision: added an 'AIR-ID' field to Section 1 so a completed questionnaire can be traced to the Register (AIG-INV-04) and Gate Log (AIG-DEC-04). No change to existing questions or structure.	Commercial and Procurement Lead
1.3 draft	29 September 2026	QA remediation — applied findings QA-091, QA-119, QA-168, QA-185, QA-199, QA-221 (see QA change log). Footer, document control and properties aligned to a single version (previously footer v1.1, document control v1.2). Final tidy-up: self-referencing cross-reference removed from the standards row(s) REQ-039, REQ-051.	Commercial and Procurement Lead
1.4 draft	30 September 2026	v3.9.1: standards cross-reference adds REQ-054 (Civil Contingencies Act 2004; section 8 Business Continuity answers support the AIG-OPS-01 section 8 fallback) and cites the 54-entry requirement inventory (AIG-AIMS-05). Proposed — for Council confirmation.	Commercial and Procurement Lead
1.5 draft	30 September 2026	v3.9.2 (pilot-readiness fixes from the scenario test; see QA change log): introduction adds the Gate 4 rule for AI features under an existing contract or licence and free public tools: Gate 4 recorded “N/A — existing contract / free tool” with rationale, while the data processing terms and sections 5 and 8 are still completed (Playbook §5.5.1; AIG-DEC-01; OA-07, T-07, T-08). Proposed — for Council confirmation.	Commercial and Procurement Lead
1.6 draft	1 October 2026	v3.9.3: standards gap closure against NCSC, NIST AI 600-1 and ISO/IEC 42005 (see QA change log, sheet “v3.9.3 changes”): new questions 4.4 (energy use, carbon footprint, data-centre locations and sustainability commitments; C4), 5.4 (secure by default), 5.5 (model protection and update integrity) and 5.6 (vulnerability disclosure) (NCSC guidelines 3.5, 3.2 and 4.4; C5); standards cross-reference note cites the 55-entry requirement inventory (AIG-AIMS-05 REQ-055, NIST AI 600-1 Generative AI Profile, added). Proposed — for Council confirmation.	Commercial and Procurement Lead
1.7 draft	2 October 2026	v3.9.5: standards cross-reference note cites the 56-entry requirement inventory (AIG-AIMS-05 REQ-056, SI 2026/425 ICO statutory code of practice on AI and automated decision-making, added). Proposed — for Council confirmation.	Commercial and Procurement Lead

Version	Date	Change summary	Owner
1.8 draft	4 October 2026	v3.9.9: agentic supplier note: undisclosed component detail is recorded as “Not disclosed by supplier” in AIG-AGT-04 and as a risk here and in AIG-ASS-02 (Playbook F.3). Proposed — for Council confirmation.	AI Governance Lead
1.9 draft	12 October 2026	v3.9.10: standards cross-reference note cites the 58-entry requirement inventory (AIG-AIMS-05 REQ-057 DAMA-DMBOK and REQ-058 ISO/IEC 5259, added as voluntary data governance references). Proposed — for Council confirmation.	AI Governance Lead

NOT APPROVED — PROPOSED INTEGRATION ANNEX

Integration annex — Supplier, model and contractual change control

DRAFT FOR COUNCIL REVIEW • 25 September 2026 • Not approved for operational use

Supplier evidence remains native

The questionnaire and supplier responses remain the native due-diligence record; distinguish supplier assertions from Council verification and executed contractual terms. Following registration, join with the AIR-ID in AIG-INV-04. Index supporting responses, assurance artefacts and contract versions in the proposed AIG-INV-04 Evidence Index by Evidence ID, exact source/version, date and location; do not treat a questionnaire response or a procurement recommendation as a verified result or award.

Change and follow-through

Capture material supplier, sub-processor, hosting/location, model, training-data, functionality, security or contract changes with the old/new version, notice/effective date, impact and accountable owner. Update AIG-INV-04 current state/change history and reassess the affected DPIA, EIA, HRA, RAIA, model card and security evidence; track live operational monitoring in AIG-OPS-02. Cite AIG-DEC-04 only to a dated actual Gate Event or Condition (ID/date), not a planned gate. The authorised procurement/governance decision remains in its native decision record, AIG-DEC-03 or authoritative minutes; AIG-DEC-04 is only a dated pointer.

Rights and agent permissions

Where the supplier enables agentic capability, record the exact model/tool/interface and boundary; permissions and delegation are controlled in AIG-AGT-04, AIG-AGT-05 is its derived authority view, and AIG-AGT-06 records relevant action decisions. Where the supplier will not disclose component detail (models, training data, sub-components or internal architecture), record “Not disclosed by supplier” in AIG-AGT-04 and record the gap as a risk here and in AIG-ASS-02; the core Agent Record fields are answered by the Council (Playbook F.3). Link affected-person challenge arrangements to AIG-OPS-04. These cross-references do not themselves constitute supplier assurance, contract acceptance, permission, approval, or legal applicability.

Procurement regime — provisional, contract-level review required. Selection of the Procurement Act 2023 regime or any applicable legacy Public Contracts Regulations 2015 transitional arrangements is not determined by this questionnaire. The contracting authority / contract owner must confirm the applicable regime against the contract facts, procurement timeline and transitional provisions before relying on this assessment, with Commercial and Legal review as appropriate. This note is a review prompt, not legal advice or a regime determination.

Draft status

Council evaluation remains an internal assessment and must not be read as procurement approval. No supplier claim, test result, contract execution, legal conclusion, approval, or publication is asserted by this integration annex.

Standards and legal applicability — proposed QA cross-reference

PROPOSED QA INDEX — NOT APPROVED LEGAL ADVICE OR EVIDENCE OF COMPLIANCE. The listed instruments may be relevant to this artefact, but applicability depends on the case, service and Council delegation. Legislation, official guidance, Council policy and voluntary standards are different authority classes. The full 58-entry requirement inventory, authoritative URLs, validation owners and current versions are in AIG-AIMS-05; source checks are in AIG-AIMS-13. Do not treat a template, plan or cross-reference as completed assessment, adopted policy, ISO conformity or legal sign-off.

Requirement / instrument	Why check it here	Source
REQ-001 — UK General Data Protection Regulation (UK GDPR), as amended	Where personal data is processed; test each UK GDPR provision separately.	https://www.legislation.gov.uk/eur/2016/679/contents
REQ-015 — Procurement Act 2023 and Procurement Regulations 2024	For an in-scope procurement; contract owner determines current or transitional regime.	https://www.legislation.gov.uk/ukpga/2023/54/contents
REQ-017 — Public Contracts Regulations 2015 and procurement transitional arrangements	Only for a legacy/transitional procurement to which PCR 2015 still applies.	https://www.gov.uk/government/collections/transforming-public-procurement
REQ-039 — NCSC Guidelines for Secure AI System Development	Screen the government security guidance requirement against this artefact's actual use and record evidence/version.	https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development/introduction
REQ-051 — AI supplier contracts, data-processing/data-sharing agreements, partnership	Screen the contractual / partnership requirement against this artefact's actual use and	Case-specific controlled contract or agreement — link from AI Register

arrangements, grants and funding conditions	record evidence/version.	
REQ-054 — Civil Contingencies Act 2004 (Category 1 responder duties, including business continuity arrangements)	Where an AI use supports a service the Council has identified as a prioritised activity in its business continuity plans; Legal / Emergency Planning to confirm; the section 8 Business Continuity answers should support the fallback recorded in AIG-OPS-01 section 8.	https://www.legislation.gov.uk/ukpga/2004/36/contents